

HACKER ATTACK

HACKER ATTACK



1

SUMÁRIO

1 HACKER ATTACK	3
1.1 Introdução	3
1.2 Descobrindo segredos.....	3
2 ACESSO CONCEDIDO.....	5
REFERÊNCIAS.....	6

EMANIP

1 HACKER ATTACK

1.1 Introdução

Olá! Seja muito bem-vindo(a) à quarta fase do segundo ano letivo do curso superior em Defesa Cibernética do FIAP ON! Nessa fase você irá se aprofundar em uma variedade de temas cruciais dentro da segurança cibernética, preparando-se para enfrentar os desafios contemporâneos nesta área em constante evolução. O foco estará em técnicas avançadas e estratégias essenciais para proteger sistemas e redes contra as ameaças mais sofisticadas.

A importância da segurança cibernética nunca foi tão crítica. De acordo com um estudo recente da IBM, foi constatado que, no Brasil, o tempo médio para identificar e conter uma violação de dados foi de 335 dias, com um custo médio que ultrapassa US\$ 7,29 milhões.

Nesse cenário, a formação em técnicas de *Pentesting*, revisão de código e análise de vulnerabilidades torna-se essencial. A fase é projetada para ensinar e engajar na aplicação prática desses conhecimentos, através de simulações e estudos de caso que refletem situações reais de sistemas e dados contra ameaças cibernéticas.

1.2 Descobrindo segredos

Chegou a hora de revelar um resumo do que você encontrará pela frente:

- **Cap 02 - Baú do tesouro ...:** Falaremos sobre a importância do *Code Review*, aliado ao conhecimento das vulnerabilidades existentes, e daremos uma introdução sobre bancos de dados e o famoso SGBD.
- **Cap 03 - Conhecendo mais o código:** Hora de entender sobre Fuzzing! A técnica de Fuzzing não é necessariamente nova, porém muitos desenvolvedores e SysAdmins desconhecem suas funcionalidades e benefícios em uma implementação segura.
- **Cap 04 - Proteções sobre o código:** Avançando na esfera do conhecimento que visa proteger e blindar o código de uma aplicação,

veremos técnicas de proteção sobre aplicações e, posteriormente, avaliaremos boas práticas para o desenvolvimento seguro.

- **Cap 05 - Secrets of the Developers:** Nos aprofundaremos na sintaxe DML e na manipulação dos dados dentro de um banco de dados, parte essencial do estudo sobre a estrutura e o funcionamento geral.
- **Cap 06 - Hora de "codar":** Entenderemos a programação dinâmica, uma técnica que permite muita flexibilidade ao desenvolvedor na projeção de código, para lidar com as diferentes informações provenientes do usuário ou de um banco de dados.
- **Cap 07 - OWASP:** Detectar pontos de falha em *softwares* e aplicações é uma das atividades de um profissional de cyber security, porém não basta identificá-las; é preciso explorá-las para que sejam caracterizadas em níveis de risco e impacto. Para tal, o conhecimento do projeto OWASP é fundamental para a eliminação de falsos positivos e foco nas devidas correções.
- **Cap 08 - Ataques de injeção:** Analisaremos as diferenças entre programação dinâmica em linguagens compiladas, como Java, e interpretadas, como Python, destacando que a maior flexibilidade de Python pode introduzir vulnerabilidades de segurança. Discutiremos técnicas para mitigar essas vulnerabilidades, focando em injeção de código e segurança de serviços web e APIs.
- **Cap 09 - SQL Injection:** Esse ataque pode causar verdadeiros desastres dependendo da habilidade de SQL do atacante. Iremos entender como funciona e como um sistema pode identificar essa vulnerabilidade e pará-la ou, ainda, como não permitir o *input* de qualquer *injection*.
- **Cap 10 - Hijacking:** Apresentaremos técnicas de sequestro de sessão de usuário (*session hijacking*), que são muito utilizadas por serem de fácil implementação e execução. É possível reduzir o impacto desses ataques realizando simples verificações e validações na estrutura que controla a sessão dos usuários.
- **Cap 11 - Security Mobile:** Hora de abordarmos o uso do *mobile phishing*, que tem crescido exponencialmente nos últimos anos devido ao uso intensivo dos smartphones por parte dos usuários. A técnica consiste desde

injetar vulnerabilidades em uma aplicação mobile até a imitação de websites legítimos, de forma que o usuário não perceba que está em um site falso.

- **Cap 12 - Code Review:** Iremos aprofundar ainda mais esse tema. Você aprenderá a realizar um *code review* eficiente e orientado à segurança de aplicações web, tendo como base as práticas mais recentes de análise manual.
- **Cap 13 - Testes de Segurança:** O entendimento dos mais diversos tipos de ferramentas e suas aplicabilidades é fundamental para o trabalho de um profissional de *cyber security*. Por isso, falaremos sobre o SAST. O *Static Application Security Testing* - ou Teste Estático de Segurança - é um teste automatizado que analisa o código-fonte para localizar vulnerabilidades que fazem com que as aplicações fiquem suscetíveis a ataques.
- **Cap 14 - Web Hacking Fundamentals:** Realizar um *Pentest* é uma arte, além de requerer técnica e conhecimento. Aqui, analisaremos as etapas e procedimentos para a realização de um *Pentest Web* profissional e completo.

2 ACESSO CONCEDIDO

E chegamos a mais uma etapa da sua jornada cibernética. Chegou a hora de se tornar um Pentester e encontrar falhas que, com alguns truques e um pouco de paciência, podem ser exploradas.

Boa sorte na sua jornada *hacker*!

REFERÊNCIAS

IBM. Relatório da IBM: as crescentes interrupções nos negócios pelas violações de dados aumentam os custos de cibersegurança no Brasil. 2024. Disponível em: <https://brasil.newsroom.ibm.com/codb2024#:~:text=A%20dura%C3%A7%C3%A3o%20m%C3%A9dia%20das%20viola%C3%A7%C3%B5es,milh%C3%B5es%20em%20m%C3%A9dia%20por%20viola%C3%A7%C3%A3o>. Acesso em: 25 abr. 2025.

EMAS